GSI, Inc.

Genius AI and RapidReconciler® Systems

SOC 2® Type 2 Report

For the Period

April 1, 2025 - March 31, 2026

UHY LLP
uhy-us.com | An independent member of UHY International

Contents

Section 1: Independent Service Auditor's Report 3

Section 2: GSI's Management Assertion 7

Section 3: GSI's Description of its Genius AI and RapidReconciler® Systems 9

Overview 10

Scope of the System 10

Description of the Service Offerings Provided 10

Principal Service Commitments and System Requirements 11

Components of the System 11

Relevant Aspects of Internal Controls 14

Trust Services Criteria and Related Controls 18

Complementary Subservice Organization Controls 19

Complementary User Entity Controls 19

Section 4: Trust Services Criteria, Related Controls, and Tests of Controls 20

Guidance Regarding Tests of Controls 21

Applicable Trust Services Criteria 21

Section 5: Other Information Provided by GSI That is Not Covered by the Service Auditor's Report 43

Section 1: Independent Service Auditor's Report

INDEPENDENT SERVICE AUDITOR'S REPORT ON A SOC 2 EXAMINATION

To the Management of:
GSI, Inc.
Atlanta, GA 30328

Scope

We have examined GSI, Inc.'s (GSI) accompanying description of its Genius AI and RapidReconciler® systems found in Section 3 titled "GSI's Description of its Genius AI and RapidReconciler® Systems" throughout the period April 1, 2025 to March 31, 2026 (description) based on the criteria for a description of a service organization's system set forth in *DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (With Revised Implementation Guidance—2022)*, in AICPA, *Description Criteria*, (description criteria) and the suitability of the design and operating effectiveness of controls stated in the description throughout the period April 1, 2025 to March 31, 2026, to provide reasonable assurance that GSI's service commitments and system requirements were achieved based on the trust services criteria relevant to security (applicable trust services criteria) set forth in *TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus—2022)*, in AICPA, *Trust Services Criteria*.

GSI uses subservice organizations to provide the services outlined in Section 3. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at GSI, to achieve GSI's service commitments and system requirements based on the applicable trust services criteria. The description presents GSI's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of GSI's controls. The description does not disclose the actual controls at the subservice organization. Our examination did not include the services provided by the subservice organization, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at GSI, to achieve GSI's service commitments and system requirements based on the applicable trust services criteria. The description presents GSI's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of GSI's controls. Our examination did not include such complementary user entity controls and we have not evaluated the suitability of the design or operating effectiveness of such controls.

The information included in Section 5, "Other Information Provided by GSI That Is Not Covered by the Service Auditor's Report," is presented by GSI's management to provide additional information and is not a part of GSI's description of its Genius AI and RapidReconciler® systems made available to user entities during the period April 1, 2025 to March 31, 2026. Information about GSI's management response to exceptions identified in the report has not been subjected to the procedures applied in the examination and accordingly, we express no opinion on it.

Service Organization's Responsibilities

GSI is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that GSI's service commitments and system requirements were achieved. In Section 2, GSI has provided the accompanying

assertion titled “GSI’s Management Assertion” (assertion) about the description and the suitability of design and operating effectiveness of controls stated therein. GSI is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria and stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization’s service commitments and system requirements.

Service Auditor’s Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the AICPA. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the examination engagement.

An examination of a description of a service organization’s system and the suitability of the design and operating effectiveness of controls involves—

- Obtaining an understanding of the system and the service organization's service commitments and system requirements.
- Assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively.
- Performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria.
- Performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- Testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- Evaluating the overall presentation of the description.

Our examination also included performing such other procedures as we considered necessary in the circumstances.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual report users may consider important to meet their informational needs. There are inherent limitations in any system of internal control, including the possibility of human error and the circumvention of controls. Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization’s service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design or operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of Tests of Controls

The specific controls we tested and the nature, timing, and results of those tests are listed in Section 4, "Trust Services Criteria, Related Controls, and Tests of Controls" of this report.

Opinion

In our opinion, in all material respects—

a. The description presents GSI's Genius AI and RapidReconciler® systems that was designed and implemented throughout the period April 1, 2025 to March 31, 2026 in accordance with the description criteria.

b. The controls stated in the description were suitably designed throughout the period April 1, 2025 to March 31, 2026 to provide reasonable assurance that GSI's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period and if the subservice organizations applied the complementary controls assumed in the design of GSI's controls throughout that period.

c. The controls stated in the description operated effectively throughout the period April 1, 2025 to March 31, 2026 to provide reasonable assurance that GSI's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls assumed in the design of GSI's controls operated effectively throughout that period.

Restricted Use

This report, including the description of tests of controls and results thereof in Section 4, is intended solely for the information and use of GSI; user entities of GSI's Genius AI and RapidReconciler® systems during some or all of the period April 1, 2025 to March 31, 2026, business partners of GSI subject to risks arising from interactions with the Genius AI and RapidReconciler® systems, practitioners providing services to such user entities and business partners, prospective user entities and business partners, and regulators who have sufficient knowledge and understanding of the following:

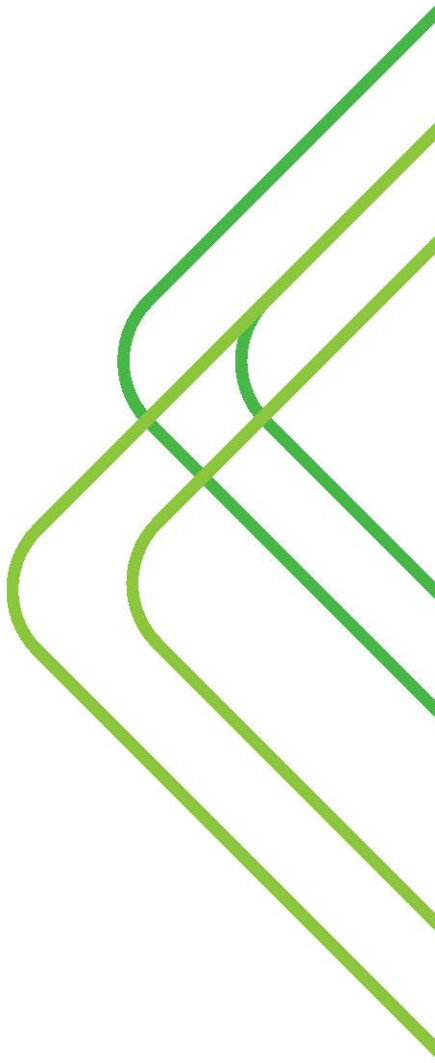
- The nature of the service provided by the service organization.
- How the service organization's system interacts with user entities, business partners, subservice organizations, and other parties.
- Internal control and its limitations.
- Complementary subservice organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements.
- User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services.
- The applicable trust services criteria.
- The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks.

This report is not intended to be, and should not be, used by anyone other than the specified parties.

UHY LLP

St. Louis, MO
June 23, 2026

Section 2: GSI's Management Assertion



GSI's Management Assertion:

We have prepared the accompanying description of GSI, Inc.'s ("GSI") Genius AI and RapidReconciler® systems titled "GSI Description of its Genius AI and RapidReconciler® Systems" throughout the period April 1, 2025 to March 31, 2026 (description) based on the criteria for a description of a service organization's system set forth in *DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (With Revised Implementation Guidance—2022)*, in AICPA, *Description Criteria* (description criteria). The description is intended to provide report users with information about the Genius AI and RapidReconciler® systems that may be useful when assessing the risks arising from interactions with GSI's system, particularly information about system controls that GSI has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security (applicable trust services criteria) set forth in *TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus—2022)*, in AICPA, *Trust Services Criteria*.

GSI uses subservice organizations to provide the services outlined in Section 3. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at GSI, to achieve GSI's service commitments and system requirements based on the applicable trust services criteria. The description presents GSI's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of GSI's controls. The description does not disclose the actual controls at the subservice organization.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at GSI, to achieve GSI's service commitments and system requirements based on the applicable trust services criteria. The description presents the service organization's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of the service organization's controls.

We confirm, to the best of our knowledge and belief, that—

1) The description presents GSI's Genius AI and RapidReconciler® systems that was designed and implemented throughout the period April 1, 2025 to March 31, 2026 in accordance with the description criteria.

2) The controls stated in the description were suitably designed throughout the period April 1, 2025 to March 31, 2026 to provide reasonable assurance that GSI's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and if the subservice organizations applied the complementary controls assumed in the design of GSI's controls throughout that period.

3) The controls stated in the description operated effectively throughout the period April 1, 2025 to March 31, 2026 to provide reasonable assurance that GSI's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls assumed in the design of GSI's controls operated effectively throughout that period.

Section 3:
GSI's Description of its Genius AI and RapidReconciler® Systems

Overview

GSI, Inc. (GSI or the Company) is a privately held corporation established in 2004 Alpharetta, Georgia that provides project consulting and managed services for Oracle JD Edwards, Oracle NetSuite, Oracle Cloud, Salesforce, ServiceNow, BMC, HubSpot, as well as other enterprise applications. As part of its full-service consulting and managed service provisions, GSI utilizes advanced Artificial Intelligence (AI) and automation to deliver internally developed software and services for the JD Edwards ERP software suite.

Scope of the System

The system description has been prepared to provide information on GSI's control environment for its Genius AI and RapidReconciler® systems (Systems) throughout the period of April 1, 2025 to March 31, 2026 in relation to the security trust services category.

Subservice Organizations

GSI utilizes a third-party provider (subservice organization) to support its Genius AI and RapidReconciler® systems. The subservice organization and the service provided include:

Subservice Organization	Services Provided
Microsoft Azure	Cloud hosting services

The scope of this report includes only GSI's Genius AI and RapidReconciler® systems, and does not include the controls in place at the subservice organization.

Significant Changes to the Systems

There were no significant changes to the in-scope systems during the attestation period. Any changes to the control activities or processes related to the in-scope system are included in Section 4, "Trust Services Criteria, Related Controls, and Test of Controls."

Identified System Incidents

No significant incidents have occurred related to the services provided to user entities during the attestation period.

Significant Subsequent Events

There were no significant events subsequent to the attestation period and through the date of the report that would materially impact the systems.

Description of the Service Offerings Provided

The GSI Genius AI application is a Software as a Service (SaaS) solution internally developed by GSI. The Genius AI application is hosted in Microsoft Azure, highly configurable and can be customized based on GSI customer needs to monitor the JD Edwards platform. Data that is utilized for monitoring is stored by JD Edwards and user entities, data is not stored by GSI.

The RapidReconciler® application is a SaaS solution hosted in Microsoft Azure that GSI clients utilize to streamline their inventory reconciliation process, minimize the number of items requiring reconciliation and provide easy support for audits. It has been designed to streamline customers using JD Edwards inventory, in-transit and Received Not Vouchered (RNV) to the General Ledger (GL) reconciliation process.

Data that is utilized for these processes is stored by JD Edwards and user entities, data is not stored by GSI.

Principal Service Commitments and System Requirements

GSI designs its processes and procedures related to GSI's systems to meet its objectives. Those objectives are based on the service commitments that GSI makes to user entities, the laws and regulations that govern the provision of the services, and the financial, operational and compliance requirements that GSI has established for the services.

Security commitments to user entities are documented and communicated in service agreements and other customer agreements, as well as in the description of the service offering provided online. Security commitments include:

- Security policies and procedures are in place and communicated to employees.
- Access to the system is restricted through the use of secure authentication mechanisms and roles based access control.
- Security systems and processes are in place to protect and monitor the System and respond to identified security incidents.
- Development practices are designed to ensure that changes are documented, authorized and tested.
- Vendor management processes are utilized to address the risks associated with the use of service providers.

GSI establishes operational requirements that support the achievement of security, relevant laws and regulations, and other system requirements. Such requirements are communicated in system policies and procedures, system design documentation and agreements with customers. Information security policies define an organization-wide approach to how systems and data are protected. These include policies around how the service is designed and developed, how the system is operated, how the internal business systems and networks are managed, and how employees are hired and trained. In addition, how to carry out specific manual and automated processes required in the operation and development of the system.

Components of the System

System Boundaries

The systems include the people, processes, and technology that make up the infrastructure responsible for supporting GSI's Genius AI and RapidReconciler® applications.

Infrastructure

The GSI application infrastructure is located in the Microsoft Azure Cloud. Azure acts as the cloud hosting subservice organization for the Company. The subservice organization provides the physical security and environmental protection controls as well as managed services for the GSI system infrastructure.

Software

GSI uses mostly Microsoft products and services, such as Windows servers and desktop operating systems, Microsoft Azure SQL (PaaS), and Microsoft Azure Active Directory are utilized. The helpdesk uses ServiceNow to manage ticketing requests.

GSI uses the following software to monitor its databases and application metrics:

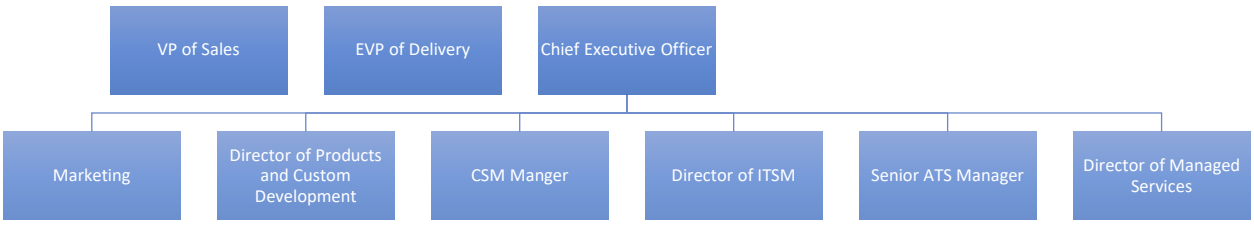
- Microsoft Azure (built in monitors)

- Genius AI (internally developed)
- SentinelOne (antivirus)
- Cisco Umbrella (cloud security)
- ProofPoint (email security)
- Microsoft Intune (endpoint manager)
- AdminDroid (Microsoft Office 365 logging)

People

GSI employs dedicated team members to handle all major product functions, including operations, and support. The IT team monitors the environment, as well as manages data backups and recovery. The Company focuses on hiring the right people for the right job as well as training them on their specific tasks and on the ways to keep GSI and its data secure.

The following is a hierarchical depiction of the Company's management structure and key functional managers.



Chief Executive Officer

Assigns authority and responsibility to key management personnel with the skills and experience necessary to carry out their assignments. Such assignments commonly relate to achieving corporate objectives, oversight of operating functions, and any compliance with applicable regulatory requirements.

VP of Sales

Oversees the sales team and the ultimate revenue of the Company.

EVP of Delivery

Responsible for developing and managing the overall service delivery strategy and operations for the Company.

Director of Managed Services

Responsible for developing and managing the overall managed service strategy for the Company and strategic changes to the managed service product.

Marketing

Oversees the Company's marketing strategy, including policies, goals, and initiatives.

Director of Products and Custom Development

Manages and oversees alternative conceptualization of AI that focuses on AI's assistive role, emphasizing the fact that it is designed to enhance human intelligence rather than replace it.

CSM Manager

Works with customers to ensure they're receiving the tools and support needed to achieve their goals.

Director of ITSM

Provides leadership for a central department within the Division of Information Technology Services. This position is responsible for championing best practices and managing a team for the development of service management processes.

Senior Advanced Technology Services Manager

Ensures revenue targets are achieved by driving efficiency and performance of the managed services team.

Processes, Policies, and Procedures

The automated and manual procedures related to the services provided, including, as appropriate, procedures by which service activities are initiated, authorized, performed, delivered, reports and other information prepared.

GSI employs a set of procedures in order to obtain the stated objectives for network and data security, data privacy, and integrity for both the Company and its clients. The definition and execution of these procedures are performed by trained, qualified, and experienced members of the GSI team.

Management has developed and communicated to employees, all relevant policies and procedures. Reviews and changes to the following policies and procedures are performed annually and are approved by senior management.

- Employee Handbook
- Personal Data Breach Plan
- Written Information Security Plan (WISP)
- Employee Agreement Computer Usage Policy
- Backup and Recovery
- Compliance Specialist Policy
- Destruction of Protected Information
- Contingency Plan Policy
- Passwords Policy
- Privacy and Security Incident Policy
- Risk Analysis and Management Policy
- Sanctions Policy
- Virus Protection
- Computer, Email, and Internet Usage Policy
- Business Continuity
- Risk Management
- SDLC
- Patching

Data

Information takes many forms. It may be stored on computers, transmitted across networks, printed or written on paper, and spoken in conversations. All employees and contractors of GSI are obligated to respect and, in all cases, to protect confidential and private data. Customer information, employment-related records, and other intellectual property-related records are, subject to limited exceptions, confidential as a matter of law. Many other categories of records, including Company, other personnel records, and records relating to GSI's business and finances are, as a matter of GSI policy, treated as confidential. Responsibility for guaranteeing appropriate security for data, systems, and networks is

shared by the Client Services and IT Departments. IT is responsible for designing, implementing, and maintaining security protection and retains responsibility for ensuring compliance with the policy. In addition to management and the technology staff, individual users are responsible for the equipment and resources under his or her control.

GSI has policies and procedures in place to ensure proper disposal of confidential and private data. The retention and data destruction policies define the retention periods and proper destruction procedures for the disposal of data. These policies are reviewed at least every two years. The destruction of data is a multi-step process. Client data is deleted upon termination of the contract. First, all files received or generated from the client are identified and deleted by the system engineering team then the product team deletes all user related data.

Electronic communications are treated with the same level of confidentiality and security as physical documents. Networks are protected by appropriate enterprise-class virus protection in place. Password protection, with assigned user rights, is required for access to the network, application, and databases. Access to the network, application, and databases is restricted to authorized internal and external users of the system to prohibit unauthorized access to confidential data. Additionally, access to data is restricted to authorized applications to prevent unauthorized access outside the boundaries of the system.

Relevant Aspects of Internal Controls

The security category and applicable trust services criteria were used to evaluate the suitability of design and operation effectiveness of controls stated in the description. The controls supporting the applicable trust services criteria are included in Section 4 of this report.

Control Environment

The control environment is the set of standards, processes, and structures that provide the basis for carrying out internal control across an organization. The organizational structure, separation of job responsibilities by departments and business function, documentation of policies and procedures, and internal audits are the methods used to define, implement, and assure effective operational controls. The compliance officer and/or senior management establish the tone at the top regarding the importance of internal control and expected standards of conduct.

Management Controls, Philosophy, and Operating Style

Management is responsible for directing and controlling operations, establishing, communicating, and monitoring control policies and procedures, as well as setting the tone for the organization. Importance is placed on accuracy and integrity, maintaining written and updated procedures, security and privacy, and establishing and maintaining sound internal controls over all functional aspects of operations.

Management's philosophy and operating style affect the way the entity is managed, including the kinds of business risks accepted. GSI places a great deal of importance on working to ensure that the integrity of processing is a primary focus and that controls are maximized to mitigate risk in daily operations. Management and specific teams are structured to ensure the highest level of integrity and efficiency in customer support and transaction processing.

Formal job descriptions, departmental meetings, and staff interactions ensure communication of organizational values, ethics, and behavior standards. Personnel operate under GSI's policies and procedures, including confidentiality agreements and security policies. Monthly training is conducted to communicate the importance of privacy and security. Management is committed to being aware of regulatory and economic changes that impact lines of business and monitoring the customer base for trends, changes, and anomalies.

Hiring and Termination Practices

GSI requires all potential candidates to submit an employment application that includes education, professional experience, and certifications. Background investigations are performed for new employees and include identification number (e.g. social security) trace and criminal background checks.

New employees are provided with an Employee Handbook. The Employee Handbook includes policies on code of conduct, confidentiality, and conflicts of interest. New employees are required to sign an acknowledgement of receipt and understanding of the Employee Handbook and Code of Conduct and are required to sign an acknowledgement form indicating they have received and understand the requirements of those policies.

Performance reviews are expected to be conducted at least annually by the employee's manager to discuss expectations, goals, and improvement plans.

Training and Supervision

New employees are trained on the specific duties and responsibilities of their respective positions. During training, employees become familiar with GSI's policies and procedures, including those related to their specific position and to GSI in general. When changes to policy are made, employees are supplied with copies of the amended policy. GSI policies pertain to confidentiality, information sensitivity, personal behavior, and rules of conduct. Policies state that employees are prohibited from divulging confidential information regarding client affairs or taking action not in the interests of the client or GSI.

Training of personnel for specific job-related duties is accomplished through supervised on-the-job training. Positions require completion of specific training before working independently on behalf of clients. In-house promotion with additional responsibilities within a service group or with another group is dependent on the understanding of the responsibilities of the current position and the proper performance of the duties of that position.

Security Awareness

GSI conducts security training programs for all employees in the areas of security and confidentiality. All employees are required to complete security awareness training monthly. Each member of the Company is made aware of the security implications that revolve around their functions and actions. Approaching security as an organization has a more profound effect than relying solely on a single group.

Risk Assessment

Risk assessment involves a dynamic iterative process for identifying and analyzing risks to achieving the organization's objectives, forming a basis for determining how risks should be managed. Management considers possible changes in the external environment and within its own organization that may impede its ability to achieve its objectives.

Business Risks

GSI's management, both individually and collectively, regard monitoring risk as an ongoing responsibility. Management is responsible for identifying and analyzing the risks relative to the achievement of the Company's objectives through the use of information derived from various sources, such as:

- Management input
- Previous monitoring activity
- Industry experience and knowledge
- Business environment
- Planned system and process changes

On an annual basis, executive management reviews the GSI strategic plan, which contains GSI's objectives and assumptions for the coming period. The strategic plan takes the following items into account:

- The Company's industry
- GSI's strategies and position in particular, including, but not limited to:
    - Corporate and operating segment financial performance
    - Business unit key strategies
    - Critical issues facing the corporation

Once reviewed and approved by upper management the strategic plan is communicated to senior management, and relevant areas are communicated to employees through various channels.

Risk Mitigation

In addition to assessing risk, management is responsible for mitigating risks. Risk mitigation strategies include prevention, mitigation, and detection through the implementation of internal controls and transference through commercial general and umbrella policies. Management takes various steps, including items described in other sections herein, to mitigate risk. For instance, management is responsible for making decisions to ensure that the internal network and the sensitive data stored there is securely protected from unauthorized access; many of the steps taken to mitigate these risks are described in the Information and Communication section of this document.

Control Activities

Control activities are the actions established by policies and procedures to help ensure that management directives to mitigate risks to the achievement of objectives are executed. Control activities are performed at all levels of the organization and at various stages within business processes, and over the technology environment.

Logical Security

GSI handles the administrative responsibilities involved in supporting the web, application, and database components of the platform. GSI has access to log into their servers remotely using secure shell (SSH) or N-able, depending on the platform. Dedicated Azure security groups and access controls are in place and used to restrict administrative access to servers.

Logical access to GSI's networks, applications and data is limited to properly authorized individuals. For both the client-hosted network and the GSI local network, logical access is controlled via standard user authentication credentials (user ID and password). No other outside access is permitted.

Physical Security

The Company's production servers are maintained at the third-party cloud provider data center and the physical security and environmental protections are the responsibility of the subservice organization. Management obtains and reviews SOC reports annually to monitor the physical security and environmental protection controls in place at the facility.

Network and Data Security

Azure's network security uses hardware and software-based intrusion prevention, advanced content filtering, anti-malware, and anti-spam modules. In addition to the Azure Security Groups, GSI uses anti-virus and anti-spyware applications to protect systems from viruses.

GSI's WISP and security procedures ensure that all computer devices (including servers, desktops, printers, etc.) connected to the GSI network have proper virus protection software, current virus definition libraries, and the most recent operating system and security patches installed. The IT

department verifies that all known and reasonable defenses are in place to reduce network vulnerabilities while keeping the network operating. In the event of a virus threat, the anti-virus system will attempt to delete or quarantine the infected file. If the virus cannot be deleted or quarantined, the infected machine will be disconnected from the network and cleaned manually.

Multiple controls are installed to monitor traffic that could contain malicious programs or code. BitSight is used for continual vulnerability scanning monitored by management for potential improvements. Server operating systems utilize anti-virus and anti-spyware programs. All employee workstation computers have a minimum standard hardware and software configuration. Employees are not allowed to install any software on GSI-owned computers. IT staff maintains several replacement computers that can replace workstations in need of repair or maintenance, thereby disrupting the employee's workday as little as possible.

GSI takes a proactive approach to patch management. Network engineers regularly monitor various websites, message boards, and mailing lists where advanced notifications of bug related patches are often disclosed prior to a public announcement by the vendor. This allows the Company to plan ahead for upcoming patches.

The networking team reviews the availability of patches and independently determine if it is necessary to deploy within the production environment. Approved patches are scheduled for installation in the test environment on a weekly basis as applicable. If there are no issues found during testing in the test environment, the patch will be applied to the production environment.

Change Management

For internally developed software solutions, GSI uses an agile-based Systems Development Life Cycle (SDLC) process, which includes research and planning, analysis and design, initial development, and Quality Assurance (QA) testing before final release. All software development activities follow the internal project-related business process model.

GSI has implemented various technologies to automate its SDLC, specifically Bitbucket to control access to code and Jira workflow to help automate specific aspects of the development process.

Information and Communication

Information is necessary for the entity to carry out internal control responsibilities in support of achievement of its objectives. Communication occurs both internally and externally and provides the Cloud Services organization with the information needed to carry out day-to-day controls. Communication enables personnel to understand internal control responsibilities and their importance to the achievement of the objective.

Internal Communication

GSI uses a variety of methods for communication to ensure that significant events and issues are conveyed in a timely manner and that staff understand their role and responsibility. These methods include new hire training, ongoing training, policy and procedure updates, use of email to communicate time-sensitive information, and the documentation and storage of historical data in internal repositories for business and support activities. Additional communication methods include periodic department meetings between each manager and their staff to discuss new Company policies, procedures, and other business issues, electronic mail messages, and the posting of information via corporate intranet on topics such as reporting of information security incidents and procedures for change management.

Personnel meet annually, or more often as needed, for major corporate announcements. Communication is encouraged at all levels to promote the operating efficiency of GSI.

External Communication

News about the Company, the industry, and upcoming events is provided to customers via the GSI application. The entity's security commitments regarding the System are included in the master services agreement. Targeted mailings and e-mails are also sent as needed to customers to communicate information of interest to them and related to the Company's analysis of issues that may affect them.

Monitoring Activities

Ongoing evaluations, separate evaluations or some combination of the two are used to ascertain whether each of other components of internal control is present and functioning. Findings are evaluated and deficiencies are communicated in a timely manner, with serious matters reported to senior management and/or the board, as deemed appropriate.

Management of GSI receives and reviews the SOC 2® report of Microsoft Azure on an annual basis. In addition, through its daily operational activities, management of GSI monitors the services performed by Microsoft Azure to ensure that operations and controls expected to be implemented at the subservice organization are functioning effectively.

Trust Services Criteria and Related Controls

GSI's applicable trust services criteria and their related controls are included in Section 4, "Trust Services Criteria, Related Controls, and Test of Controls," to eliminate the redundancy that would result from listing them in this section and repeating them in Section 4. Although the trust services criteria and related controls are included in Section 4, they are, nevertheless, an integral part of GSI's description of controls.

Complementary Subservice Organization Controls

GSI's controls related to the Genius AI and RapidReconciler® systems cover only a portion of overall internal control for each user entity of GSI. It is not feasible for the applicable trust services criteria related to security to be met solely by GSI. Therefore, each user entity's internal control for security must be evaluated in conjunction with GSI's controls described in Section 4 of this report, taking into account the related complementary subservice organization controls expected to be implemented at the subservice organization as described below.

Complementary Subservice Organization Controls	Applicable TSC
Environmental protection controls are in place within the cloud data centers.	CC7.2
Physical access to cloud data centers is restricted to authorized personnel and monitored.	CC6.4
Administrative logical security for cloud data centers is restricted to authorized personnel and monitored.	CC6.1 - CC6.3 & CC6.5 & CC6.6
Physical access card usage is logged. These logs are maintained and reviewed by the security staff.	CC6.4
Documented procedures exist for the identification and escalation of potential physical security breaches.	CC7.4
When the information on physical assets no longer requires logical and physical access protection they are securely disposed.	CC6.5
Firewalls and an Intrusion Detection System (IDS) are installed and monitored to protect the production environment.	CC7.1
Infrastructure upgrades and patches, including production servers, are authorized, tested, if applicable, documented, properly implemented, and approved.	CC8.1

Complementary User Entity Controls

GSI's internal controls related to the applicable trust services criteria for security of the Genius AI and RapidReconciler® System cover only a portion of overall internal control for each user entity of GSI. Complementary controls at user entities are required to achieve the applicable trust services criteria for security. Therefore, each user entity's internal control relative to security should be evaluated in conjunction with GSI's controls described in Section 4 of this report, taking into account the related complementary user entity controls associated with the relevant applicable trust services criteria, as indicated below.

In order for user entities to rely on the controls reported on herein, each user entity must evaluate its own internal control to determine whether the identified complementary user entity controls have been implemented and are operating effectively.

Complementary User Entity Controls	Applicable TSC
User entities are responsible for granting secure access to GSI employees for installations or updates to the Genius AI and RapidReconciler® agents.	CC6.1, CC6.2, CC6.3 & CC8.1

Section 4: Trust Services Criteria, Related Controls, and Tests of Controls

Guidance Regarding Tests of Controls

When using information produced by the service organization, we evaluated whether the information was sufficiently reliable for our purposes, including, as necessary, obtaining evidence about the completeness and accuracy of the information and evaluating whether the information was sufficiently precise and detailed for our purposes.

The types of tests that may have been performed in evaluating the effectiveness of controls include inquiry, observation, inspection and/or re-performance.

Applicable Trust Services Criteria

Category	Description
Security	Information and systems are protected against unauthorized access, unauthorized disclosure of information, and damage to systems that could compromise the availability, integrity, confidentiality, and privacy of information or systems and affect the entity's ability to meet its objectives.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 1	**Common Criteria Related to Control Environment**		
CC1.1	**The entity demonstrates a commitment to integrity and ethical values.**		
Internal policies and procedures are updated as necessary and are made available to all employees via the Company SharePoint site.		Inspected a selection of internal policies and procedures to determine they have been created and are updated as necessary. Inspected SharePoint site to determine internal policies and procedures are available to all employees.	No exceptions noted.
Personnel are required to read and accept the Code of Conduct standard of conduct found in the Employee Handbook upon hire.		Inspected the acceptance of the Code of Conduct for a sample of new hires to determine the code of conduct is accepted upon hire.	No exceptions noted.
The Company has a confidential mechanism available to employees to report Code of Conduct complaints. Complaints are addressed by HR within 10 days.		Inspected complaint procedures to determine that a confidential reporting mechanism is in place and available to employees to report Code of Conduct complaints. Inspected the Company grievance log to determine there were no grievances filed during the examination period.	Attribute not tested as there were no grievances filed during the examination period. No exceptions noted on the remaining tests performed.
All personnel are required to complete a background check prior to hire.		Inspected completed background checks for a sample of new hires to determine that a background check is completed prior to hire.	Exception noted: 1 of 3 sampled new hires did not have a background check completed prior to hire. The new hires background check was completed 6 days subsequent to their hire date.
CC1.2	**The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.**		
The compliance officer meets with management annually to discuss the performance of internal controls and internal risk items.		Inspected meeting invites to determine that the compliance officer meets with management at least annually to discuss performance of internal controls and risks.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 1	**Common Criteria Related to Control Environment**		
Documented organizational charts are in place that define organizational structure and reporting lines.		Inspected company organizational charts to determine that they are in place and define organizational structure and reporting lines.	No exceptions noted.
CC1.3	**Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.**		
Documented organizational charts are in place that define organizational structure and reporting lines.		Inspected company organizational charts to determine that they are in place and define organizational structure and reporting lines.	No exceptions noted.
Roles and responsibilities are defined in written job descriptions.		Inspected a selection of job descriptions to determine that roles and responsibilities are defined.	No exceptions noted.
CC1.4	**The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.**		
Performance meetings are conducted quarterly for all employees that are client facing. Operational employees meet quarterly with their managers, to discuss performance.		Inspected meeting documentation for a sample of employees to determine performance meetings are conducted quarterly to discuss performance.	No exceptions noted.
Roles and responsibilities are defined in written job descriptions.		Inspected a selection of job descriptions to determine that roles and responsibilities are defined.	No exceptions noted.
CC1.5	**The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.**		
Performance meetings are conducted quarterly for all employees that are client facing. Operational employees meet quarterly with their managers, to discuss performance.		Inspected meeting documentation for a sample of employees to determine performance meetings are conducted quarterly to discuss performance.	No exceptions noted.
All employees receive security awareness training at least quarterly.		Inspected the KnowBe4 user listing to determine all employees are enrolled in security awareness training. Inspected KnowBe4 summary reports for a sample of current employees to determine security awareness trainings were received at least quarterly.	No exceptions noted.
Roles and responsibilities are defined in written job descriptions.		Inspected a selection of job descriptions to determine that roles and responsibilities are defined.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 2	**Common Criteria Related to Communication and Information**		
CC2.1	**The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.**		
The Company has implemented various policies and procedures relevant to security that support the functioning of internal control. These are made available to all employees via the Company SharePoint site.		Inspected GSI policies and procedures relevant to security to determine they have been created and are made available to all employees on the Company SharePoint site. Inspected SharePoint site to determine policies and procedures relevant to security are available to all employees.	No exceptions noted.
The Company performs a formal risk assessment annually. Risks to the Company and its objectives are considered, including those related to fraud and vendors, as part of the assessment.		Inspected the formal risk assessment to determine that it is performed annually and risks to the company and objectives are considered, including fraud.	No exceptions noted.
External network vulnerability scans are performed monthly. Vulnerabilities identified are remediated in accordance with Company policy.		Inspected external vulnerability scan results for a sample of months to determine that scans are performed monthly. Inspected vulnerability scanning results from the period to determine that vulnerabilities identified are remediated in accordance with Company policy.	No exceptions noted.
CC2.2	**The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.**		
The Company has implemented various policies and procedures relevant to security that support the functioning of internal control. These are made available to all employees via the Company SharePoint site.		Inspected GSI policies and procedures relevant to security to determine they have been created and are made available to all employees on the Company SharePoint site. Inspected SharePoint site to determine policies and procedures relevant to security are available to all employees.	No exceptions noted.
Roles and responsibilities are defined in written job descriptions.		Inspected a selection of job descriptions to determine that roles and responsibilities are defined.	No exceptions noted.
All employees receive security awareness training at least quarterly.		Inspected the KnowBe4 user listing to determine all employees are enrolled in security awareness training. Inspected KnowBe4 summary reports for a sample of current employees to determine security awareness trainings were received at least quarterly.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 2	**Common Criteria Related to Communication and Information**		
CC2.3	**The entity communicates with external parties regarding matters affecting the functioning of internal control.**		
Procedures for handling of any incidents, including notification of affected external parties, are outlined in the Incident Response Plan.		Inspected the Incident Response Plan to determine that procedures for handling any incidents, including notification of affected external parties were outlined within the plan.	No exceptions noted.
Management has communicated its Privacy Policy to external parties via the Company's website.		Inspected the Privacy Policy to determine that management has communicated it to external parties via the company's website.	No exceptions noted.
Service level agreements and security requirements are communicated to key external parties via contractual documents.		Inspected templated contractual documents to determine that they contained service level agreements and security requirements.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 3	**Common Criteria Related to Risk Assessment**		
CC3.1	**The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.**		
The Company performs a formal risk assessment annually. Risks to the Company and its objectives are considered, including those related to fraud and vendors, as part of the assessment.		Inspected the formal risk assessment to determine that it is performed annually and risks to the company and objectives are considered, including fraud.	No exceptions noted.
Management evaluates control activities on its key business processes and technology during the annual risk assessment. Controls are developed or modified with collaboration from the process owners as needed based on the results of the assessment.		Inspected the formal risk assessment and risk register to determine that it evaluates control activities of key business processes and technology and new controls are developed or modified as needed based on the results of the assessment.	No exceptions noted.
CC3.2	**The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.**		
The Company performs a formal risk assessment annually. Risks to the Company and its objectives are considered, including those related to fraud and vendors, as part of the assessment.		Inspected the formal risk assessment to determine that it is performed annually and risks to the company and objectives are considered, including fraud.	No exceptions noted.
A master list of Company assets is maintained, accounting for additions and removals.		Inspected the Intune asset listing to determine that a master list of the company's system components is maintained, accounting for additions and removals.	No exceptions noted.
External network vulnerability scans are performed monthly. Vulnerabilities identified are remediated in accordance with Company policy.		Inspected external vulnerability scan results for a sample of months to determine that scans are performed monthly. Inspected vulnerability scanning results from the period to determine that vulnerabilities identified are remediated in accordance with Company policy.	No exceptions noted.
Incidents are tracked and resolved using a ticketing system. A root cause analysis (RCA) process is followed when deemed necessary.		Inspected tickets for a sample of incidents to determine that they are tracked and resolved within the ticketing system. Inspected tickets for a sample of incidents to determine a root cause analysis process is followed when deemed necessary.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 3	**Common Criteria Related to Risk Assessment**		
CC3.3	**The entity considers the potential for fraud in assessing risks to the achievement of objectives.**		
The Company performs a formal risk assessment annually. Risks to the Company and its objectives are considered, including those related to fraud and vendors, as part of the assessment.		Inspected the formal risk assessment to determine that it is performed annually and risks to the company and objectives are considered, including fraud.	No exceptions noted.
Personnel are required to read and accept the Code of Conduct standard of conduct found in the Employee Handbook upon hire.		Inspected the acceptance of the Code of Conduct for a sample of new hires to determine the code of conduct is accepted upon hire.	No exceptions noted.
The Company has a confidential mechanism available to employees to report Code of Conduct complaints. Complaints are addressed by HR within 10 days.		Inspected complaint procedures to determine that a confidential reporting mechanism is in place and available to employees to report Code of Conduct complaints. Inspected the Company grievance log to determine there were no grievances filed during the examination period.	Attribute not tested as there were no grievances filed during the examination period. No exceptions noted on the remaining tests performed.
CC3.4	**The entity identifies and assesses changes that could significantly impact the system of internal control.**		
The Company performs a formal risk assessment annually. Risks to the Company and its objectives are considered, including those related to fraud and vendors, as part of the assessment.		Inspected the formal risk assessment to determine that it is performed annually and risks to the company and objectives are considered, including fraud.	No exceptions noted.
Management evaluates control activities on its key business processes and technology during the annual risk assessment. Controls are developed or modified with collaboration from the process owners as needed based on the results of the assessment.		Inspected the formal risk assessment and risk register to determine that it evaluates control activities of key business processes and technology and new controls are developed or modified as needed based on the results of the assessment.	No exceptions noted.
Incidents are tracked and resolved using a ticketing system. A root cause analysis (RCA) process is followed when deemed necessary.		Inspected tickets for a sample of incidents to determine that they are tracked and resolved within the ticketing system. Inspected tickets for a sample of incidents to determine a root cause analysis process is followed when deemed necessary.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 3	**Common Criteria Related to Risk Assessment**		
External network vulnerability scans are performed monthly. Vulnerabilities identified are remediated in accordance with Company policy.		Inspected external vulnerability scan results for a sample of months to determine that scans are performed monthly. Inspected vulnerability scanning results from the period to determine that vulnerabilities identified are remediated in accordance with Company policy.	No exceptions noted.
A software development process is in place using a ticketing system that follows ITIL standards and includes testing and approval of software changes.		Inspected the software development process to determine that a process was in place using a ticketing system that follows ITIL standards and includes testing and approval of changes.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 4	**Common Criteria Related to Monitoring Activities**		
CC4.1	**The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.**		
External network vulnerability scans are performed monthly. Vulnerabilities identified are remediated in accordance with Company policy.		Inspected external vulnerability scan results for a sample of months to determine that scans are performed monthly. Inspected vulnerability scanning results from the period to determine that vulnerabilities identified are remediated in accordance with Company policy.	No exceptions noted.
Phishing exercises are performed monthly and remedial training is required for those who fail.		Inspected the KnowBe4 phishing tool reports to determine that exercises are performed monthly and required remedial training for those that failed.	No exceptions noted.
The Company performs a formal risk assessment annually. Risks to the Company and its objectives are considered, including those related to fraud and vendors, as part of the assessment.		Inspected the formal risk assessment to determine that it is performed annually and risks to the company and objectives are considered, including fraud.	No exceptions noted.
Monitoring tools are in place to report anomalies to IT and tickets are logged for issues that require remediation.		Inspected the population of IT anomalies to determine that none required a ticket to be created and verified that response by reviewing the completed actions of the threats. Inspected the monitoring tools to determine that monitoring is in place and configured to report anomalies to IT.	Attribute not tested. There were no incidents that required tickets to be created for remediation during the examination period. No exceptions noted on the remaining tests performed.
Management evaluates control activities on its key business processes and technology during the annual risk assessment. Controls are developed or modified with collaboration from the process owners as needed based on the results of the assessment.		Inspected the formal risk assessment and risk register to determine that it evaluates control activities of key business processes and technology and new controls are developed or modified as needed based on the results of the assessment.	No exceptions noted.
CC4.2	**The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.**		
Procedures for handling of any incidents, including notification of affected external parties, are outlined in the Incident Response Plan.		Inspected the Incident Response Plan to determine that procedures for handling any incidents, including notification of affected external parties were outlined within the plan.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 4	**Common Criteria Related to Monitoring Activities**		
Incidents are tracked and resolved using a ticketing system. A root cause analysis (RCA) process is followed when deemed necessary.		Inspected tickets for a sample of incidents to determine that they are tracked and resolved within the ticketing system. Inspected tickets for a sample of incidents to determine a root cause analysis process is followed when deemed necessary.	No exceptions noted.
The compliance officer meets with management annually to discuss the performance of internal controls and internal risk items.		Inspected meeting invites to determine that the compliance officer meets with management at least annually to discuss performance of internal controls and risks.	No exceptions noted.
Management evaluates control activities on its key business processes and technology during the annual risk assessment. Controls are developed or modified with collaboration from the process owners as needed based on the results of the assessment.		Inspected the formal risk assessment and risk register to determine that it evaluates control activities of key business processes and technology and new controls are developed or modified as needed based on the results of the assessment.	No exceptions noted.
A data breach team has been established with the centralized responsibility for administering and maintaining information security.		Inspected the Cybersecurity and Privacy Incident Response Policy and the Personal Data Breach Plan to determine that a data breach team is established with centralized responsibilities of administering and maintaining information security.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 5	**Common Criteria Related to Control Activities**		
CC5.1	**The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.**		
The Company performs a formal risk assessment annually. Risks to the Company and its objectives are considered, including those related to fraud and vendors, as part of the assessment.		Inspected the formal risk assessment to determine that it is performed annually and risks to the company and objectives are considered, including fraud.	No exceptions noted.
Management evaluates control activities on its key business processes and technology during the annual risk assessment. Controls are developed or modified with collaboration from the process owners as needed based on the results of the assessment.		Inspected the formal risk assessment and risk register to determine that it evaluates control activities of key business processes and technology and new controls are developed or modified as needed based on the results of the assessment.	No exceptions noted.
Procedures for handling of any incidents, including notification of affected external parties, are outlined in the Incident Response Plan.		Inspected the Incident Response Plan to determine that procedures for handling any incidents, including notification of affected external parties were outlined within the plan.	No exceptions noted.
Incidents are tracked and resolved using a ticketing system. A root cause analysis (RCA) process is followed when deemed necessary.		Inspected tickets for a sample of incidents to determine that they are tracked and resolved within the ticketing system. Inspected tickets for a sample of incidents to determine a root cause analysis process is followed when deemed necessary.	No exceptions noted.
CC5.2	**The entity also selects and develops general control activities over technology to support the achievement of objectives.**		
Management evaluates control activities on its key business processes and technology during the annual risk assessment. Controls are developed or modified with collaboration from the process owners as needed based on the results of the assessment.		Inspected the formal risk assessment and risk register to determine that it evaluates control activities of key business processes and technology and new controls are developed or modified as needed based on the results of the assessment.	No exceptions noted.
The Company has implemented various policies and procedures relevant to security that support the functioning of internal control. These are made available to all employees via the Company SharePoint site.		Inspected GSI policies and procedures relevant to security to determine they have been created and are made available to all employees on the Company SharePoint site. Inspected SharePoint site to determine policies and procedures relevant to security are available to all employees.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 5	**Common Criteria Related to Control Activities**		
CC5.3	**The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.**		
Internal policies and procedures are updated as necessary and are made available to all employees via the Company SharePoint site.		Inspected a selection of internal policies and procedures to determine they have been created and are updated as necessary. Inspected SharePoint site to determine internal policies and procedures are available to all employees.	No exceptions noted.
Roles and responsibilities are defined in written job descriptions.		Inspected a selection of job descriptions to determine that roles and responsibilities are defined.	No exceptions noted.
All employees receive security awareness training at least quarterly.		Inspected the KnowBe4 user listing to determine all employees are enrolled in security awareness training. Inspected KnowBe4 summary reports for a sample of current employees to determine security awareness trainings were received at least quarterly.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 6	**Common Criteria Related to Logical and Physical Access Controls**		
CC6.1	**The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.**		
Firewalls are configured to restrict unauthorized access to the environment. All traffic not explicitly allowed is denied.		Inspected the firewall security rules for Genius AI and RapidReconciler® Azure subscriptions to determine that they are configured to restrict unauthorized access and all traffic not explicitly allowed is denied.	No exceptions noted.
MFA is used for all GSI employees to authenticate to Azure.		Observed a GSI employee login to Azure to determine MFA is used for GSI employees to authenticate to Azure. Inspected configurations to determine MFA is used for all GSI employees to authenticate to MS Azure.	No exceptions noted.
Administrator access to in-scope systems is limited to appropriate individuals based on job responsibility.		Inspected administrative users listings for in-scope systems to determine that administrative access is limited to appropriate individuals based on job responsibilities.	No exceptions noted.
Unique user IDs and passwords are used to control GSI access to in-scope systems. Passwords settings are configured according to the Company password policy.		Inspected the user listings for in-scope systems to determine that unique user IDs are used. Inspected the password settings for in-scope systems and the company password policy to determine they are configured in accordance with the company password policy.	No exceptions noted.
CC6.2	**Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.**		
Procedures for granting, changing, and terminating access are documented in the Company's onboarding, offboarding and change management processes.		Inspected the onboarding, offboarding, and change management process to determine that procedures for granting, changing, and terminated access are documented in the company's processes.	No exceptions noted.
New or modified access to in-scope systems and supporting infrastructure is authorized by appropriate personnel. Access is granted based on roles and responsibilities taking into consideration the principle of least privilege.		Inspected tickets for a sample of new hires to determine that access to in-scope systems and supporting infrastructure is authorized by appropriate personnel and granted based on roles and responsibilities taking into consideration the principle of least privilege. Inspected updated user listings for a sample of active employees with a job change to determine that there was no modification to their access to in-scope systems and supporting infrastructure.	Attribute not tested. No modified access was noted during the engagement period. No exceptions noted on the other procedures performed.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 6	**Common Criteria Related to Logical and Physical Access Controls**		
Termination procedures are in place to ensure access for terminated employees is suspended within 24 hours of their termination date.		Inspected tickets for a sample of terminated employees to determine that termination procedures are utilized to ensure suspension of access is completed within 24 hours of their termination date.	No exceptions noted.
Access to in-scope systems is reviewed by management at least annually to ensure access is appropriate.		Inspected the access review for in-scope systems to determine access was reviewed by management annually to ensure access is appropriate.	No exceptions noted.
Customers are required to authenticate to in-scope systems prior to accessing data. The system has been configured to enforce a password length of 8 or more characters.		Observed a GSI employee attempt to access the client web portal for in-scope systems noting that a user ID and password was required. Inspected the password reset page for customer facing in-scope systems to determine they are configured to require 8 characters or more.	No exceptions noted.
CC6.3	**The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.**		
New or modified access to in-scope systems and supporting infrastructure is authorized by appropriate personnel. Access is granted based on roles and responsibilities taking into consideration the principle of least privilege.		Inspected tickets for a sample of new hires to determine that access to in-scope systems and supporting infrastructure is authorized by appropriate personnel and granted based on roles and responsibilities taking into consideration the principle of least privilege. Inspected updated user listings for a sample of active employees with a job change to determine that there was no modification to their access to in-scope systems and supporting infrastructure.	Attribute not tested. No modified access was noted during the engagement period. No exceptions noted on the other procedures performed.
Termination procedures are in place to ensure access for terminated employees is suspended within 24 hours of their termination date.		Inspected tickets for a sample of terminated employees to determine that termination procedures are utilized to ensure suspension of access is completed within 24 hours of their termination date.	No exceptions noted.
Administrator access to in-scope systems is limited to appropriate individuals based on job responsibility.		Inspected administrative users listings for in-scope systems to determine that administrative access is limited to appropriate individuals based on job responsibilities.	No exceptions noted.
Access to in-scope systems is reviewed by management at least annually to ensure access is appropriate.		Inspected the access review for in-scope systems to determine access was reviewed by management annually to ensure access is appropriate.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 6	**Common Criteria Related to Logical and Physical Access Controls**		
CC6.4	**The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.**		
Controls related to CC6.4 are the responsibility of GSI's subservice organizations. See Section 3 for Complementary Subservice Organization Controls related to this criterion.			
CC6.5	**The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.**		
Media no longer needed is wiped clean of any data and securely disposed of by IT.		Inspected disposal records for the population of disposed devices to determine media no longer needed is wiped clean of any data and securely disposed of by IT.	No exceptions noted.
CC6.6	**The entity implements logical access security measures to protect against threats from sources outside its system boundaries.**		
Firewalls are configured to restrict unauthorized access to the environment. All traffic not explicitly allowed is denied.		Inspected the firewall security rules for Genius AI and RapidReconciler® Azure subscriptions to determine that they are configured to restrict unauthorized access and all traffic not explicitly allowed is denied.	No exceptions noted.
MFA is used for all GSI employees to authenticate to Azure.		Observed a GSI employee login to Azure to determine MFA is used for GSI employees to authenticate to Azure. Inspected configurations to determine MFA is used for all GSI employees to authenticate to MS Azure.	No exceptions noted.
Malware protection software is installed and configured on all production systems and workstations to automatically and continuously update virus definitions. Administrator access to the anti-virus software is restricted to authorized individuals and requires MFA.		Inspected malware protection software configurations to determine that it is configured to automatically scan and update production server and workstation definitions daily. Inspected the malware protection software administrative user listing to determine that access is restricted to authorized individuals. Observed an administrator user log into the malware protection software to determine admin access to the anti-virus software required MFA.	No exceptions noted.
Security protocols and transport layer security (TLS) encryption is enabled for in-scope web applications.		Inspected the encryption and protocol configuration for in-scope web applications to determine that security protocols and TLS encryption is enabled.	No exceptions noted.
CC6.7	**The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.**		
Administrator access to in-scope systems is limited to appropriate individuals based on job responsibility.		Inspected administrative users listings for in-scope systems to determine that administrative access is limited to appropriate individuals based on job responsibilities.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 6	**Common Criteria Related to Logical and Physical Access Controls**		
New or modified access to in-scope systems and supporting infrastructure is authorized by appropriate personnel. Access is granted based on roles and responsibilities taking into consideration the principle of least privilege.		Inspected tickets for a sample of new hires to determine that access to in-scope systems and supporting infrastructure is authorized by appropriate personnel and granted based on roles and responsibilities taking into consideration the principle of least privilege. Inspected updated user listings for a sample of active employees with a job change to determine that there was no modification to their access to in-scope systems and supporting infrastructure.	Attribute not tested. No modified access was noted during the engagement period. No exceptions noted on the other procedures performed.
The Company deploys a security agent to all company issued devices that allows for login tokens to be revoked remotely in the event it is lost or stolen.		Inspected the configuration of the mobile device management software to determine that it was in place and configured to protect company information.	No exceptions noted.
Security protocols and transport layer security (TLS) encryption is enabled for in-scope web applications.		Inspected the encryption and protocol configuration for in-scope web applications to determine that security protocols and TLS encryption is enabled.	No exceptions noted.
Customers are required to authenticate to in-scope systems prior to accessing data. The system has been configured to enforce a password length of 8 or more characters.		Observed a GSI employee attempt to access the client web portal for in-scope systems noting that a user ID and password was required. Inspected the password reset page for customer facing in-scope systems to determine they are configured to require 8 characters or more.	No exceptions noted.
CC6.8	**The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.**		
Malware protection software is installed and configured on all production systems and workstations to automatically and continuously update virus definitions. Administrator access to the anti-virus software is restricted to authorized individuals and requires MFA.		Inspected malware protection software configurations to determine that it is configured to automatically scan and update production server and workstation definitions daily. Inspected the malware protection software administrative user listing to determine that access is restricted to authorized individuals. Observed an administrator user log into the malware protection software to determine admin access to the anti-virus software required MFA.	No exceptions noted.
Phishing exercises are performed monthly and remedial training is required for those who fail.		Inspected the KnowBe4 phishing tool reports to determine that exercises are performed monthly and required remedial training for those that failed.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 6	**Common Criteria Related to Logical and Physical Access Controls**		
External network vulnerability scans are performed monthly. Vulnerabilities identified are remediated in accordance with Company policy.		Inspected external vulnerability scan results for a sample of months to determine that scans are performed monthly. Inspected vulnerability scanning results from the period to determine that vulnerabilities identified are remediated in accordance with Company policy.	No exceptions noted.
DNS-layer security is used to block users from accessing malicious sites, prevent malicious internet connections and alert/log activity across all devices.		Inspected the ThreatLocker configuration to determine that DNS-layer security is used to block users from accessing malicious sites, prevent malicious internet connections and alert/log activity across all devices.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 7	**Common Criteria Related to System Operations**		
CC7.1	**To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.**		
Malware protection software is installed and configured on all production systems and workstations to automatically and continuously update virus definitions. Administrator access to the anti-virus software is restricted to authorized individuals and requires MFA.		Inspected malware protection software configurations to determine that it is configured to automatically scan and update production server and workstation definitions daily. Inspected the malware protection software administrative user listing to determine that access is restricted to authorized individuals. Observed an administrator user log into the malware protection software to determine admin access to the anti-virus software required MFA.	No exceptions noted.
DNS-layer security is used to block users from accessing malicious sites, prevent malicious internet connections and alert/log activity across all devices.		Inspected the ThreatLocker configuration to determine that DNS-layer security is used to block users from accessing malicious sites, prevent malicious internet connections and alert/log activity across all devices.	No exceptions noted.
External network vulnerability scans are performed monthly. Vulnerabilities identified are remediated in accordance with Company policy.		Inspected external vulnerability scan results for a sample of months to determine that scans are performed monthly. Inspected vulnerability scanning results from the period to determine that vulnerabilities identified are remediated in accordance with Company policy.	No exceptions noted.
A cloud-delivered security solution is used to detect and prevent malicious activity on in-scope systems.		Inspected the cloud-delivered security solution malware and mitigation configurations to determine it is in place to detect and prevent malicious activity on in-scope systems. Inspected audit logs throughout the period to determine events were detected on in-scope systems. Inspected alerting configurations and email groups to determine events were detected and appropriate personnel were notified.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 7	**Common Criteria Related to System Operations**		
CC7.2	**The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.**		
External network vulnerability scans are performed monthly. Vulnerabilities identified are remediated in accordance with Company policy.		Inspected external vulnerability scan results for a sample of months to determine that scans are performed monthly. Inspected vulnerability scanning results from the period to determine that vulnerabilities identified are remediated in accordance with Company policy.	No exceptions noted.
A cloud-delivered security solution is used to detect and prevent malicious activity on in-scope systems.		Inspected the cloud-delivered security solution malware and mitigation configurations to determine it is in place to detect and prevent malicious activity on in-scope systems. Inspected audit logs throughout the period to determine events were detected on in-scope systems. Inspected alerting configurations and email groups to determine events were detected and appropriate personnel were notified.	No exceptions noted.
Monitoring tools are in place to report anomalies to IT and tickets are logged for issues that require remediation.		Inspected the population of IT anomalies to determine that none required a ticket to be created and verified that response by reviewing the completed actions of the threats. Inspected the monitoring tools to determine that monitoring is in place and configured to report anomalies to IT.	Attribute not tested. There were no incidents that required tickets to be created for remediation during the examination period. No exceptions noted on the remaining tests performed.
Incidents are tracked and resolved using a ticketing system. A root cause analysis (RCA) process is followed when deemed necessary.		Inspected tickets for a sample of incidents to determine that they are tracked and resolved within the ticketing system. Inspected tickets for a sample of incidents to determine a root cause analysis process is followed when deemed necessary.	No exceptions noted.

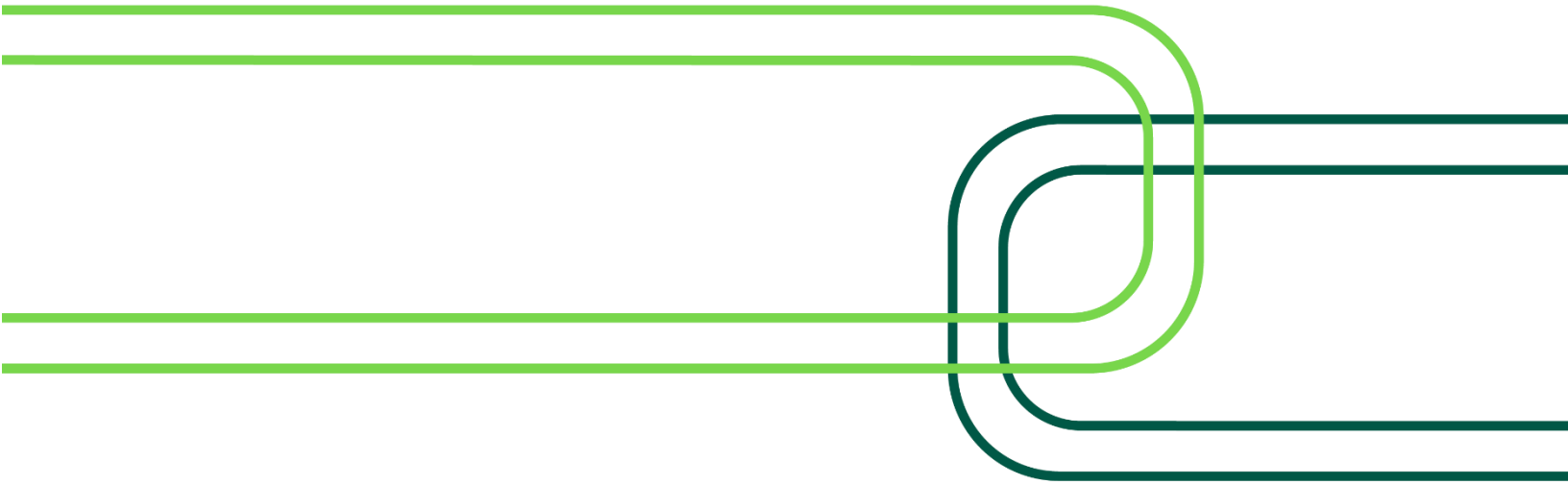
Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 7	**Common Criteria Related to System Operations**		
CC7.3	**The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.**		
Incidents are tracked and resolved using a ticketing system. A root cause analysis (RCA) process is followed when deemed necessary.		Inspected tickets for a sample of incidents to determine that they are tracked and resolved within the ticketing system. Inspected tickets for a sample of incidents to determine a root cause analysis process is followed when deemed necessary.	No exceptions noted.
A Personal Data Breach Plan is established to define the resolution and escalation of reported events.		Inspected the Personal Data Breach Plan to determine that it defines the resolution and escalation of reported events.	No exceptions noted.
CC7.4	**The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.**		
Incidents are tracked and resolved using a ticketing system. A root cause analysis (RCA) process is followed when deemed necessary.		Inspected tickets for a sample of incidents to determine that they are tracked and resolved within the ticketing system. Inspected tickets for a sample of incidents to determine a root cause analysis process is followed when deemed necessary.	No exceptions noted.
A Personal Data Breach Plan is established to define the resolution and escalation of reported events.		Inspected the Personal Data Breach Plan to determine that it defines the resolution and escalation of reported events.	No exceptions noted.
CC7.5	**The entity identifies, develops, and implements activities to recover from identified security incidents.**		
Incidents are tracked and resolved using a ticketing system. A root cause analysis (RCA) process is followed when deemed necessary.		Inspected tickets for a sample of incidents to determine that they are tracked and resolved within the ticketing system. Inspected tickets for a sample of incidents to determine a root cause analysis process is followed when deemed necessary.	No exceptions noted.
A Personal Data Breach Plan is established to define the resolution and escalation of reported events.		Inspected the Personal Data Breach Plan to determine that it defines the resolution and escalation of reported events.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 8	**Common Criteria Related to Change Management**		
CC8.1	**The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.**		
A software development process is in place using a ticketing system that follows ITIL standards and includes testing and approval of software changes.		Inspected the software development process to determine that a process was in place using a ticketing system that follows ITIL standards and includes testing and approval of changes.	No exceptions noted.
Separate environments exist for development and production.		Inspected the development and production environments for Genius AI and RapidReconciler® to determine that they are logically separate.	No exceptions noted.
Software and infrastructure changes are formally documented, approved and tested before migration to production.		Inspected tickets for a sample of software changes to determine that changes are formally documented, approved and tested prior to migration to production. Inspected tickets for a sample of infrastructure changes to determine that changes are formally documented, approved and tested prior to migration to production.	No exceptions noted.
Access to production code is limited to authorized personnel.		Inspected the listing of users with access to the production code to determine it is limited to authorized personnel. Inspected branch restrictions to determine access to production code is limited to authorized personnel.	No exceptions noted.

Common Criteria to All In-Scope Trust Services Categories			
Service Organization Control Activity		**Test Performed by the Service Auditor**	**Test Results**
CC 9	**Common Criteria Related to Risk Mitigation**		
CC9.1	**The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.**		
The Company performs a formal risk assessment annually. Risks to the Company and its objectives are considered, including those related to fraud and vendors, as part of the assessment.		Inspected the formal risk assessment to determine that it is performed annually and risks to the company and objectives are considered, including fraud.	No exceptions noted.
Management evaluates control activities on its key business processes and technology during the annual risk assessment. Controls are developed or modified with collaboration from the process owners as needed based on the results of the assessment.		Inspected the formal risk assessment and risk register to determine that it evaluates control activities of key business processes and technology and new controls are developed or modified as needed based on the results of the assessment.	No exceptions noted.
A Personal Data Breach Plan is established to define the resolution and escalation of reported events.		Inspected the Personal Data Breach Plan to determine that it defines the resolution and escalation of reported events.	No exceptions noted.
The Company obtains a cybersecurity insurance policy annually.		Inspected cybersecurity insurance policies to determine that the company obtains cybersecurity insurance policies annually.	No exceptions noted.
The Company maintains a Business Continuity and Disaster Recovery Plan to address risks arising from potential business disruptions. Backups are tested annually.		Inspected the Business Continuity and Disaster Recovery Plan to determine that they address risks arising from potential business disruptions. Inspected backup test results to determine that backups are tested annually.	No exceptions noted.
CC9.2	**The entity assesses and manages risks associated with vendors and business partners.**		
The Company performs a formal risk assessment annually. Risks to the Company and its objectives are considered, including those related to fraud and vendors, as part of the assessment.		Inspected the formal risk assessment to determine that it is performed annually and risks to the company and objectives are considered, including fraud.	No exceptions noted.
A Personal Data Breach Plan is established to define the resolution and escalation of reported events.		Inspected the Personal Data Breach Plan to determine that it defines the resolution and escalation of reported events.	No exceptions noted.
The Company performs assessments of controls at subservice organizations at least annually. Assessments include review of available SOC reports or security questionnaires.		Inspected the review of subservice organization SOC reports to determine the Company performed an assessment of its subservice organizations controls annually.	No exceptions noted.

Section 5: Other Information Provided by GSI That is Not Covered by the Service Auditor's Report

Management Response to Exceptions Identified in the Report			
Criteria	**Control Activity Specified by the Organization**	**Test Results**	**Management Response**
CC1.1	All personnel are required to complete a background check prior to hire.	Exception noted: 1 of 3 sampled new hires did not have a background check completed prior to hire. The new hires background check was completed 6 days subsequent to their hire date.	Management acknowledges that an instance occurred where the background screening for an individual was not completed prior to their start date, which is a deviation from the established control. This was a one-time exception driven by business necessity, as the individual joined the organization as part of an acquisition and was already actively supporting the related client base. To ensure continuity of operations and minimize disruption to client services, management reviewed the circumstances and approved onboarding prior to completion of the background screening.



UHY

Connect to possibility

NATIONAL

For a complete listing of our U.S. offices,
please visit: www.uhy-us.com/locations

GLOBAL

For a complete listing of our member firms,
please visit: www.uhy.com/our-locations

866-993-6723

info@uhy-us.com

"UHY" is the brand name under which UHY LLP and UHY Advisors, Inc. provide professional services. The two firms operate as separate legal entities in an alternative practice structure. UHY LLP is a licensed independent CPA firm that performs attest services. UHY Advisors, Inc. provides tax and business consulting services through subsidiary entities. UHY Advisors, Inc. and UHY LLP are U.S. members of Urbach Hacker Young International Limited (UHY International), a UK company, and form part of the international UHY network of legally independent accounting and consulting firms. Any services described herein are provided by UHY Advisors, Inc. and/or UHY LLP (as the case may be) and not by UHY International or any other member firm of UHY International. Neither UHY International nor any member of UHY International has any liability for services provided by other members.

©2025 UHY LLP. All rights reserved. [1024]

Audit | Tax | Advisor | Consulting

An independent member of UHY International